1. ควรใส่ Security ตอนไหน?

คำตอบ: ควรใส่เข้าไปใน ทุกขั้นตอน (**Every Phase)** ของวงจรการพัฒนาซอฟต์แวร์ หรือที่เรียกว่าหลักการ **"Shift-Left Security"**

- **Requirement:** กำหนดมาตรฐานความปลอดภัยตั้งแต่ตอนเก็บ **Requirement**
- **Design:** ออกแบบสถาปัตยกรรมให้ปลอดภัย (**Secure by Design)**
- **Coding:** เขียนโค้ดอย่างปลอดภัย (**Secure Coding)**
- **Testing:** ทดสอบเจาะระบบและสแกนหาช่องโหว่ (**DAST/SAST)**
- **Deployment:** ตั้งค่าเซิร์ฟเวอร์และสภาพแวดล้อมให้ปลอดภัย *การนำ **Security** เข้ามาตั้งแต่ขั้นตอนแรก ๆ จะช่วยลดช่องโหว่และประหยัดต้นทุนในการแก้ไขปัญหาได้มากที่สุด*

2. อะไรคือทรัพย์สิน (Assets) ที่ต้องปกป้อง?

คำตอบ: ทุกข้อที่ระบุมาถือเป็นทรัพย์สินสารสนเทศ (**Information Assets)** ทั้งหมด ซึ่งต้องได้รับการปกป้องตามระดับความสำคัญ:

- ข้อมูลส่วนบุคคล (**PII): ชื่อ, อีเมล, รหัสนักศึกษา,** เบอร์โทรศัพท์ (เป็นข้อมูลที่มีความละเอียดอ่อนและต้องปฏิบัติตามกฎหมาย **PDPA)**
- ข้อมูลระบบและเอกสาร: ข้อมูลการแจ้งซ่อม**, Google Sheet (**อาจมีข้อมูลความลับขององค์กร)
- สิทธิ์การเข้าถึง (**Credentials):** บัญชี **Google (**หากหลุดไป แฮกเกอร์จะสามารถเข้าถึงทรัพย์สินอื่น ๆ ได้ทั้งหมด)

3. อะไรอันตรายที่สุด?

คำตอบ: ในตัวเลือกที่ให้มา **Default Password (**รหัสผ่านเริ่มต้น) ถือเป็นช่องโหว่ที่อันตรายและถูกโจมตีได้ง่ายที่สุดในทางปฏิบัติ

- **Default Password:** แฮกเกอร์และบอทสามารถใช้สแกนและเข้ายึดระบบได้ทันทีโดยไม่ต้องใช้เทคนิคซับซ้อน (เป็นสาเหตุหลักของการถูกแรนซัมแวร์โจมตี)

4. เรียงลำดับความสำคัญ และ การป้องกัน (**Defense in Depth)**

1. **WAF (Web Application Firewall):** ด่านหน้าระดับเครือข่าย คอยกรองทราฟฟิกอันตรายก่อนเข้ามาถึงแอปพลิเคชัน
2. **Validation:** ด่านตรวจสอบระดับแอปพลิเคชัน ตรวจสอบและกรองข้อมูลที่ผู้ใช้งานนำเข้า (**Input)** ว่าถูกต้องตามรูปแบบหรือไม่
3. **Parameterized Query:** ด่านระดับฐานข้อมูล ใช้เพื่อแยกแยะระหว่างคำสั่ง **SQL** และข้อมูลผู้ใช้ ป้องกัน **SQL Injection** เด็ดขาด
4. **Least Privilege:** ด่านระดับสิทธิ์ผู้ใช้งาน จำกัดสิทธิ์ของตัวแอปพลิเคชันที่ต่อกับฐานข้อมูลให้ทำได้เฉพาะที่จำเป็น (เช่น อ่านได้อย่างเดียว ลบไม่ได้) เพื่อจำกัดความเสียหายหากระบบถูกเจาะ

5.เรียงลำดับความสำคัญ (ฝั่งการสื่อสารและยืนยันตัวตน):

1. **MFA (Multi-Factor Authentication):** สำคัญที่สุดในการปกป้องสิทธิ์ผู้ใช้งาน ป้องกันการโดนขโมยรหัสผ่าน
2. **HTTPS / TLS:** การเข้ารหัสข้อมูลระหว่างทาง (**Data in Transit)** ป้องกันการดักจับข้อมูล (**Sniffing)**
3. **API Gateway:** ด่านหน้าในการบริหารจัดการทราฟฟิกของ **API** รวมถึงการควบคุม **Rate Limit** และ **Authentication**